

Report S9L5

Sviluppo dei punti richiesti per mettere in sicurezza una rete compromessa.

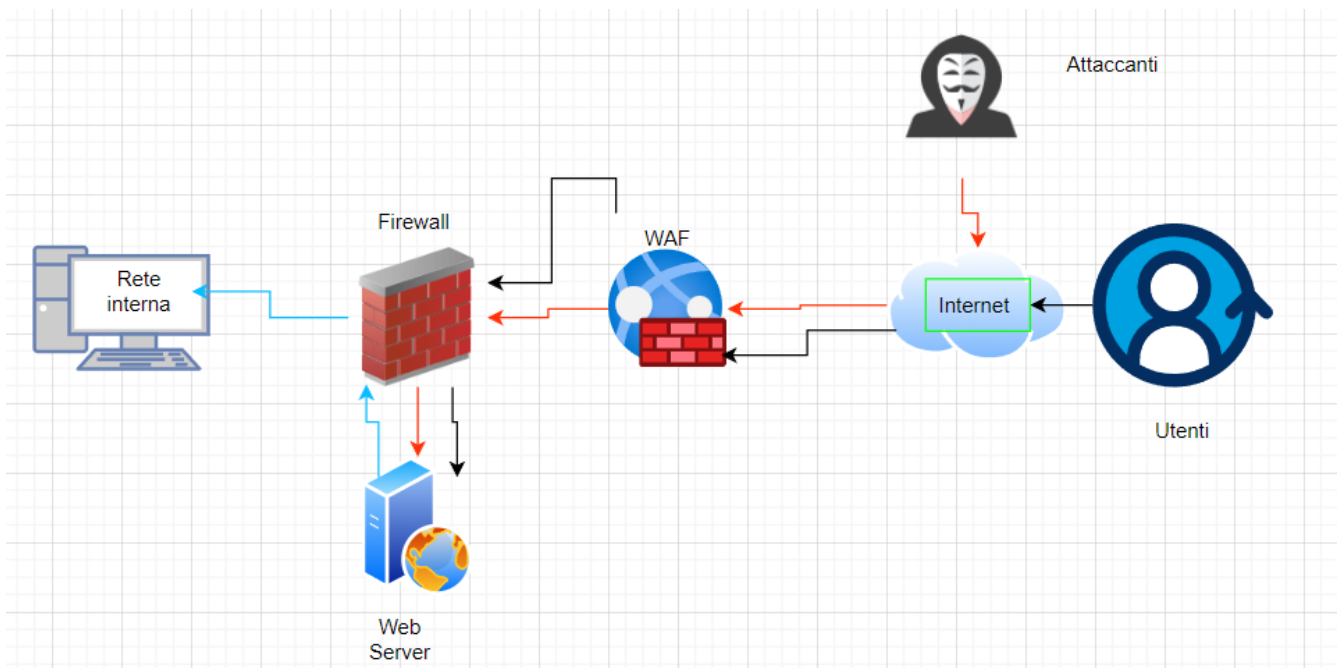
Azioni Preventive per Difendere un'Applicazione Web da Attacchi SQLi e XSS

Introduzione

Per proteggere un'applicazione web da attacchi SQL Injection (SQLi) e Cross-Site Scripting (XSS), è essenziale l'implementazione di un Web Application Firewall (WAF) e la validazione e sanificazione degli input.

Implementazione di un Web Application Firewall (WAF)

Descrizione: Un Web Application Firewall (WAF) è progettato per proteggere le applicazioni web da attacchi specifici come SQLi e XSS. Il WAF analizza e filtra il traffico HTTP/HTTPS, bloccando richieste malevoli prima che raggiungano il firewall di rete e il server web.



Impatti sul Business e Soluzioni per Attacchi DDoS

Introduzione

L'azienda è stata vittima di un attacco DDos il che ha fatto sì che il web server crollasse per 10 minuti.

Non abbiamo dati sufficienti per determinare l'MTD dell'azienda. Per affrontare tali eventi e garantire la continuità del servizio, è essenziale adottare misure efficaci. A seguito si inserisce una stima della perdita totale nei 10 minuti di shutdown, il metodo più efficace per garantire la BCI è la creazione di failover-cluster, includendo misure di protezione per gestire il rischio di infezione da malware (Il piano di implementazione viene presentato nelle pagine successive del report).

Impatto Economico dell'Interruzione del Servizio

Calcolo dell'Impatto:

- **Durata dell'Interruzione:** 10 minuti.
- **Spesa Media per Minuto:** 1.200 €.

Conclusione:

L'interruzione del servizio per 10 minuti comporterebbe una perdita economica di circa 12.000 €.

Valutazione delle Azioni Preventive

Per ridurre l'impatto di attacchi DDoS e garantire la continuità del servizio, è fondamentale adottare un approccio avanzato che includa non solo il failover ma anche la protezione da infezioni da malware. La seguente soluzione di failover avanzato è progettata per garantire la disponibilità del servizio e proteggere la rete interna.

Protezione Avanzata contro Malware

Per evitare che un'infezione da malware su un nodo del cluster comprometta l'intera rete, è necessario implementare misure di protezione avanzata.

Implementazione:

- **Segmentazione della Rete:** Isolare i nodi del cluster in segmenti di rete separati per prevenire la propagazione di malware. Utilizzare VLAN (Virtual Local Area Networks) per isolare il traffico tra i nodi del cluster e la rete interna.
- **Firewall e Controlli di Accesso:** Configurare firewall avanzati e controlli di accesso per monitorare e filtrare il traffico tra i nodi del cluster e la rete interna. Assicurarsi che solo il traffico autorizzato possa passare tra i segmenti.
- **Soluzioni Anti-Malware e IDS/IPS:** Implementare software anti-malware e sistemi di rilevamento/prevenzione delle intrusioni (IDS/IPS) sui nodi del cluster e nella rete interna. Questo aiuterà a identificare e bloccare attività malevole.
- **Backup e Ripristino:** Assicurarsi che siano implementate soluzioni di backup regolari e strategie di ripristino per ridurre l'impatto di eventuali infezioni da malware e garantire la rapidità del recupero.

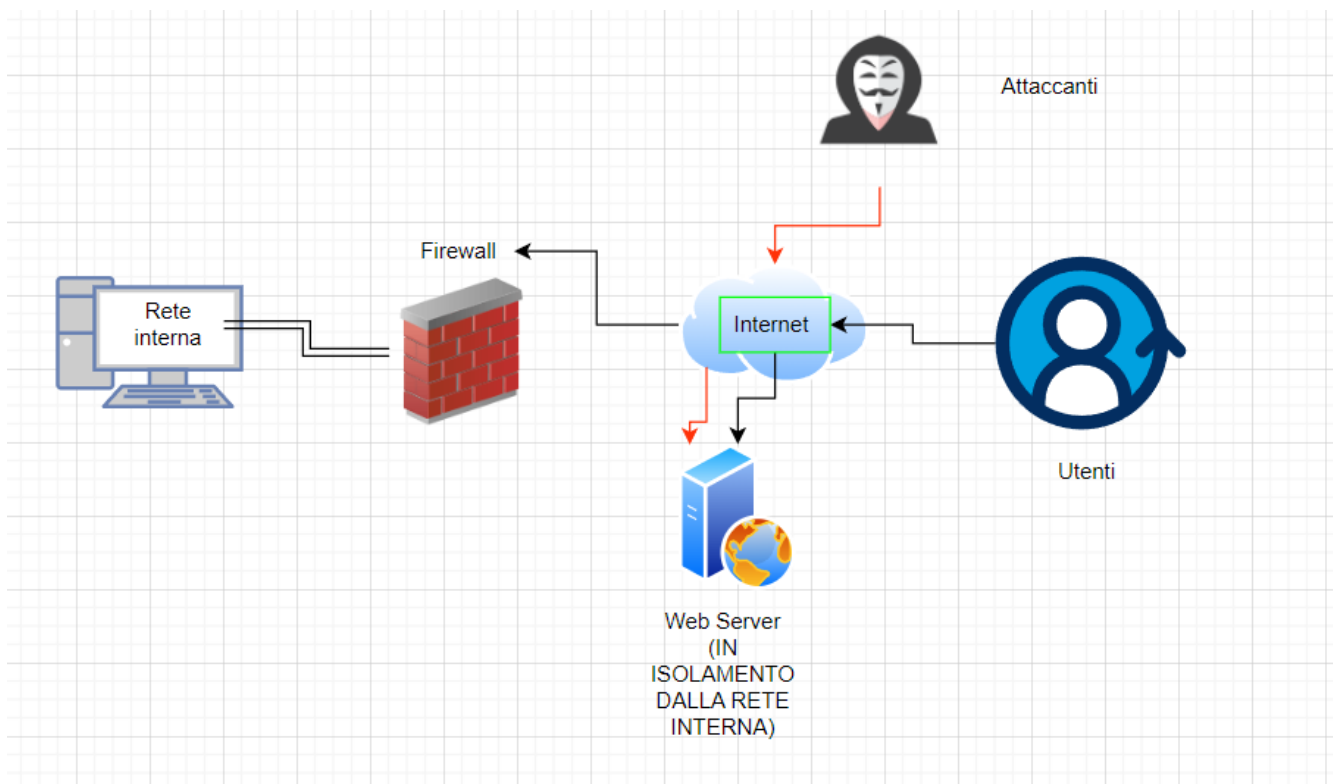
Gestione dell'Infezione da Malware

Introduzione

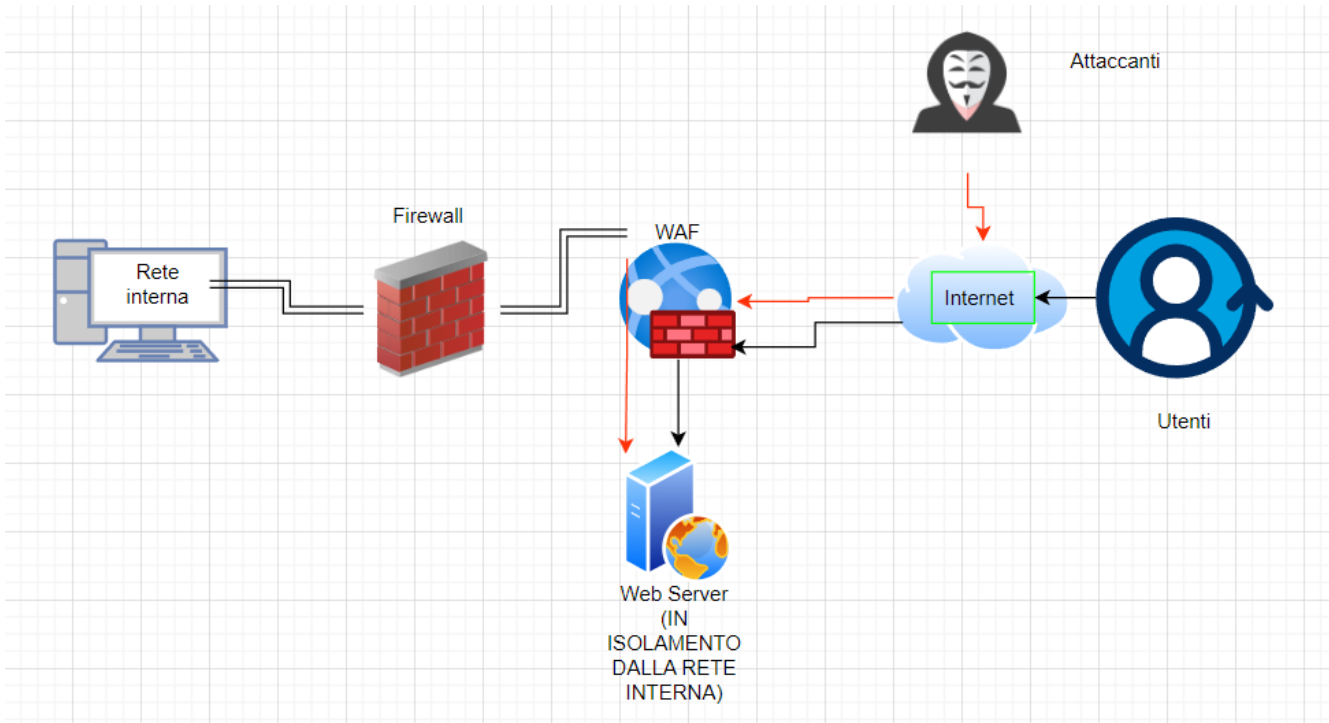
In caso di infezione da malware su un server dell'applicazione web, è essenziale adottare misure per contenere il danno, proteggere la rete interna e garantire la disponibilità del servizio agli utenti. Questo report descrive una strategia di risposta che include l'isolamento del server infetto e l'uso di un Web Application Firewall (WAF) per filtrare il traffico.

Isolamento del Server Infetto

Per contenere il malware e prevenire la diffusione alla rete interna, il server infetto deve essere staccato dalla rete interna e dal firewall, mantenendo comunque l'accesso esterno per gli utenti.



Esempio di rete con le modifiche necessarie per affrontare le minacce viste sopra



Modifiche consigliate per la completa messa in sicurezza della rete

Introduzione

In questa sezione si documentano le modifiche da apportare alla rete dell'azienda, inclusi l'aggiornamento dei dispositivi di rete, la configurazione delle UPS e l'introduzione di nuovi componenti.

Modifiche Apportate

Aggiornamento del Cisco Firepower 1010:

- Il Cisco Firepower 1010 è stato installato come nuovo firewall e proxy, in sostituzione dell'unità precedentemente in uso. Visto i risultati degli attacchi abbiamo ritenuto la macchina obsoleta e abbiamo quindi ritenuto necessario un aggiornamento.
Il Cisco Firepower 1010 integra funzioni di firewall, sistema di prevenzione delle intrusioni (IPS) e proxy, offrendo una protezione avanzata e una gestione efficiente del traffico di rete.

Introduzione del Synology DiskStation DS1819+:

- **Dettagli:** La rete non prevedeva un server di backup. Per migliorare le capacità di archiviazione e la resilienza dei dati, è stato introdotto il Synology DiskStation DS1819+ come il NAS principale. Questo cambiamento permette di gestire meglio i dati e fornire una soluzione di backup robusta per l'infrastruttura IT.

Aggiunta dei Server di Failover:

- **Dettagli:** Sono stati aggiunti due Failover Dell PowerEdge R640 e due Failover Web Server. Questi server sono progettati per garantire la continuità del servizio in caso di guasto del server primario. I failover sono configurati per assumere automaticamente il carico in caso di necessità, migliorando la disponibilità e la resilienza della rete.

Implementazione del Fortinet FortiWeb Cloud (WAF):

- **Motivazione:** Il Fortinet FortiWeb Cloud è stato integrato come Web Application Firewall (WAF) per proteggere le applicazioni web da minacce esterne e attacchi.
- **Dettagli:** Il Fortinet FortiWeb Cloud è posizionato tra l'Internet e il Cisco Firepower 1010 per una protezione avanzata delle applicazioni web.

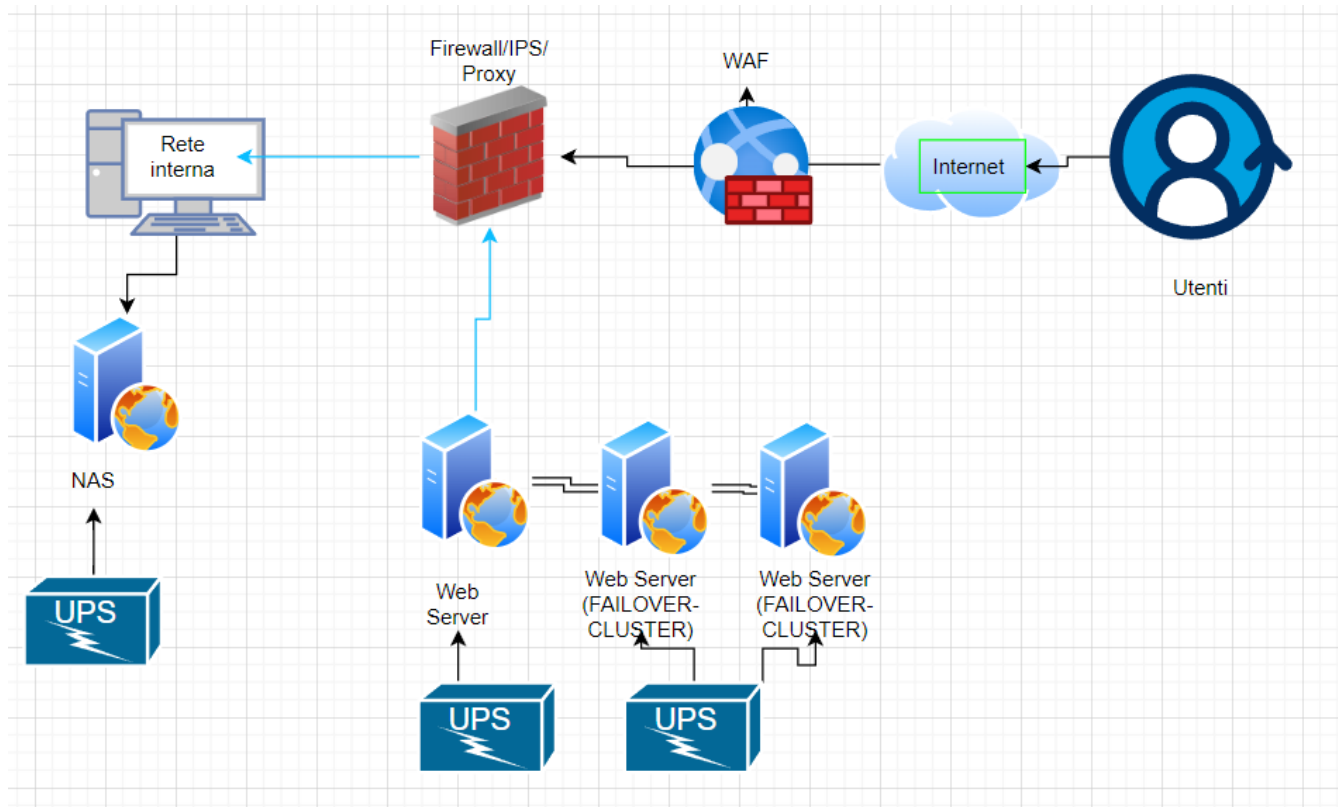
Configurazione delle UPS:

- **UPS 1 (dedicato al Primary):** Fornisce alimentazione continua Web server dell'azienda e all'Existing Web Server. Garantisce che il server primario e il web server esistente rimangano operativi durante le interruzioni di corrente.
 -
- **UPS 2 (dedicato ai Failover):** Supporta il Failover Dell PowerEdge R640, Failover Web Server 1 e Failover Web Server 2. Assicura che i server di failover abbiano alimentazione continua e siano pronti a subentrare in caso di guasti dei server primari.
 -
- **UPS 3 (dedicato al NAS):** Fornisce alimentazione continua al Synology DiskStation DS1819+, proteggendo i dati critici da interruzioni di corrente.

Considerazioni di Sicurezza:

- **Segmentazione:** I server di failover sono separati dalla rete principale del server primario per ridurre il rischio di compromissione in caso di attacchi al server primario, questo può rallentare il processo di sincronizzazione ma offre uno strato di sicurezza ulteriore per evitare lo “spreading” dell'infezione o dell'attacco.
- **Backup e Test:** È fondamentale mantenere backup regolari e testare periodicamente i meccanismi di failover per garantire che funzionino correttamente in caso di emergenze.
- **Monitoraggio:** Implementare un monitoraggio continuo delle UPS e dei dispositivi di rete per rilevare e rispondere rapidamente a eventuali problemi.

Schema di rete aggiornato e lista componenti da implementare



Ecco la lista delle parti da aggiungere alla rete, inclusi i prezzi:

1. UPS

- Atlantis A03-OP1002 UPS OnLine: €253.07 x 3 = €759.21

2. Firewall

- Cisco Firepower 1010 Master Bundle: \$1,413.55 (circa €1,300)

3. WAF

- Fortinet FortiWeb Cloud 1 application w/25 Mbps: \$29 al mese (circa €25 al mese)

4. Server per il Failover Cluster

- Dell PowerEdge R640 Server: €1,700 x 2 = €3,400

5. NAS

- Synology DiskStation DS1819+: €1,200
- Dischi rigidi da 14TB (8 unità): Circa €300 ciascuno, per un totale di circa €2,400

Costo totale stimato: €9,059.21 (escluso il costo mensile del WAF)

